Laporan Audit Keamanan: FieldOps IT v0.2.4

Audit source-first (read-only), 28 Oktober 2026. Tidak ada kode yang diubah.

Cakupan: seluruh source yang dikirim (`InventoryContext` , `Navbar` , `LoginScreen` , `UserRoleSwitcher` , `excelExporter` , `projectDownloader` , `mockData` , dan komponen lain).

Metode: penelusuran source langsung, tanpa menjalankan kode. Sandbox aman tidak tersedia di sesi ini, jadi tiap temuan adalah hasil membaca alur kode. Ini bukan pipeline multi-agent penuh dengan file laporan.

Akar masalah: aplikasi ini sepenuhnya client-side. Semua data, sesi, dan "otentikasi" ada di `localStorage` . Tidak ada server yang memegang batas kepercayaan, jadi semua kontrol akses di bawah ini hanya kosmetik. Ini juga menjelaskan klaim "Production-Ready", "terenkripsi", "Cloud SQL", dan "REST API" yang saat ini tidak punya implementasi di kode.

Ringkasan

#	Temuan	Severity
1	Login tanpa password diterima, dan akun seed (termasuk Master Admin) tidak punya password	**High**
2	`switchUser` tanpa kredensial, dan approve/reset-master tidak dibatasi role	**High**
3	Registrasi dari layar login langsung `ACTIVE` dengan role pilihan sendiri	**High**
4	RBAC hanya di UI, termasuk tombol reset/hapus data	Medium
5	Backup/ZIP membocorkan `passwordHash` + `salt` dan API key plaintext	Medium
6	Injeksi formula/HTML di ekspor Excel & CSV	Medium
7	Validasi mutasi stok lemah (qty negatif, SKU duplikat, race)	Medium
8	Hash password SHA-256 tunggal, tanpa KDF	Low
9	`performedBy` bisa dipalsukan, jejak audit tidak tepercaya	Low

#	Temuan	Severity
10	"Workspace terisolasi" bukan batas otorisasi	Low

Temuan terkonfirmasi

1. Bypass login (High)

- `InventoryContext.login()` hanya memverifikasi hash jika `target.passwordHash && target.salt && passwordAttempt` benar. Jika kolom password kosong, verifikasi dilewati dan login sukses.
- `INITIAL_USERS` (termasuk `usr-master-01`) tidak punya `passwordHash`, jadi tidak ada password sama sekali.
- `LoginScreen` mendorong ini lewat teks "Kosongkan jika akun demo default" dan tombol "1-Klik Masuk" (password hardcoded `FieldOps2026!`).
- Sesi dibaca dari `fieldops_auth_session === 'true'` dan fail-open: blok `catch` mengembalikan `true`. Mengubah nilai ini di DevTools sudah cukup untuk masuk.
- **Perbaikan minimal:** wajibkan password untuk semua akun, tolak password kosong, dan pindahkan otentikasi ke server.

2. Eskalasi hak akses (High)

- `switchUser(userId)` tidak memeriksa kredensial atau status. Dropdown di `Navbar` menampilkan seluruh `users` (termasuk `PENDING_APPROVAL` dan `REJECTED`), jadi teknisi bisa mengklik "Ahmad Alfath (Master Admin)" dan langsung menjadi master.
- `approveUser`, `rejectUser`, `addUser`, dan `setupMasterAccount` tidak punya pemeriksaan role. Panel di `UserRoleSwitcher` bisa dibuka dari menu semua role. Siapa pun bisa menyetujui akun atau menimpa email dan password Master.
- **Perbaikan minimal:** cek role dan status di setiap aksi (sisi server), dan buang `switchUser` dari produksi.

3. Persetujuan akun dilewati (High)

- `addUser` memakai `isMaster = currentUser.isMasterAdmin`. `currentUser` berasal dari `fieldops_inventory_current_user`, yang default-nya `INITIAL_USERS[0]`, yaitu Master.
- Di browser baru, orang yang mendaftar dari layar login (sebelum login) langsung `ACTIVE` dengan role yang ia pilih, misalnya supervisor.

- **Perbaikan minimal:** tentukan status berdasarkan sesi terautentikasi, bukan state yang tersimpan.

4. RBAC hanya di UI (Medium)

- `recordStockIn`, `updateItem`, `deleteItem`, `addCategory`, `generateApiKey`, `deleteApiKey`, `clearToEmptyDatabase`, dan `importDatabaseJson` tidak mengecek role.
- Tombol "Input Barang Masuk" di `TransactionHistory`, tab Integrasi (buat/cabut API key), dan `DownloadModal` (kosongkan/impor) terbuka untuk teknisi.
- "Reset Data" di `Navbar` memanggil `resetToDemoData()` langsung tanpa konfirmasi dan menghapus item, transaksi, dan log audit.
- **Perbaikan minimal:** terapkan otorisasi per aksi di lapisan data, bukan hanya menyembunyikan tombol.

5. Kebocoran kredensial lewat backup (Medium)

- `downloadJsonBackup` dan `downloadProjectZip` menyertakan `currentUser` (lengkap dengan `passwordHash` dan `salt`) serta `apiKeys` dalam teks biasa, dan bisa diakses semua role.
- API key disimpan plaintext di `localStorage`. Key bergaya `fops_live_…` juga di-hardcode di `mockData.ts` sehingga ikut ke bundle, dan kunci aktif dicetak ke contoh kode di tab Dokumentasi.
- **Perbaikan minimal:** jangan ekspor field kredensial, dan jangan simpan atau commit key bergaya produksi.

6. Injeksi formula dan HTML di ekspor (Medium)

- `excelExporter.ts` menyisipkan `item.name`, `specs`, `notes`, `recipientOrDestination`, dan lainnya ke string HTML tanpa escape.
- `handleExportCSV` hanya memberi tanda kutip, tanpa menetralkan awalan `=`, `+`, `-`, `@`.
- Judul tiket dari sistem eksternal (`ticketTitle`, `notes`) masuk ke kolom ekspor. Admin atau supervisor yang membuka file bisa terkena formula berbahaya.
- **Perbaikan minimal:** escape HTML, beri awalan `'` pada sel yang diawali karakter formula, atau pakai library XLSX asli.

7. Mutasi stok tidak divalidasi (Medium)

- `consumeStockFromTicket` dan `recordStockOut` tidak memvalidasi `quantity > 0` dan integer. Nilai negatif lolos cek `target.quantity < qty` dan malah menambah stok. `NaN` menghasilkan stok `NaN`.

- Baris dengan SKU yang sama dua kali lolos cek satu per satu terhadap stok awal, lalu stok bisa menjadi negatif.
- `FieldTripChecklistModal` bisa memilih item yang sama di dua baris. Dua pemanggilan `recordStockOut` memakai `items` yang basi, sehingga stok berkurang sekali tetapi dua transaksi `OUT` tercatat.
- Saat ini hanya terjangkau lewat UI, tetapi jadi serius begitu endpoint webhook dibuat.
- **Perbaikan minimal:** validasi input di satu fungsi mutasi dan gunakan functional `setItems` (`prev => …`).

8. Hash password lemah (Low)

SHA-256 satu putaran dengan salt cepat dibrute-force. Hash ada di `localStorage` dan di backup, dan password default (`FieldOps2026!` , `FieldOpsMaster2026!`) tertulis di source. `verifyPassword` diimpor tetapi tidak dipakai. Gunakan PBKDF2/Argon2 di server.

9. Jejak audit bisa dipalsukan (Low)

`performedBy` adalah input teks bebas di `StockInOutModal` , dan `technicianName` di simulator bebas diisi. Semua log juga bisa disunting langsung di `localStorage` .

10. Isolasi workspace (Low)

`switchWorkspace` dan `addWorkspace` bisa dipanggil siapa saja, bahkan sebelum login, dan tidak ada ikatan user ke cabang. Pemisahan hanya berupa awalan key `localStorage` .

Perlu validasi (belum bisa dipastikan dari source)

- **Firebase / Cloud SQL:** `firebase-applet-config.json` dan README menyebut keduanya, tetapi tidak ada kode atau `firestore.rules` di repo. Jika database cloud itu aktif, aturan aksesnya perlu dicek di Firebase Console. API key Firebase web memang publik, jadi keamanannya bergantung pada aturan tersebut.
- **Dev server lewat Cloudflare Tunnel:** panduan di `GoLiveModal` dan README menyarankan `npm run dev` (`host 0.0.0.0`) di-tunnel ke publik. Dev server Vite tidak dirancang untuk diekspos. Pastikan yang di-publish adalah hasil `vite build` di hosting statis.
- **Header keamanan/CSP:** `index.html` tidak punya CSP. Konfigurasi hosting tidak terlihat di repo.
- **Dependensi:** versi di `package.json` tidak diaudit karena jaringan nonaktif. Jalankan `npm audit` di mesin lokal.

Catatan di luar keamanan

- Karena data per-browser, teknisi yang mengakses lewat tunnel tidak berbagi stok. Klaim "real-time" tidak benar sampai ada backend.
- Klaim "terenkripsi SHA-256" di UI menyesatkan: hashing di klien bukan kontrol akses.
- Ekspor CSV memakai `encodeURI` pada data URL, sehingga karakter `#` memotong isi file. Itu bug integritas data.

Urutan prioritas perbaikan

1. **Pindahkan auth dan data ke backend.** Ini menyelesaikan #1–5 dan #9–10 sekaligus.
2. Perbaiki injeksi formula/HTML di ekspor (#6).
3. Validasi dan atomisasi mutasi stok (#7).